

DUCKWORKS

AI Governance Regulatory & Framework Research Report

Current official requirements and recognized guidance relevant to Project W.I.N.G.

Organization	Duckworks (fictional)
Document ID	DW-WING-REG-01
Version	1.0
Research date	10 August 2026
Evidence basis	Public primary/official sources + Duckworks fictional project baseline
Classification	Portfolio / Synthetic / Non-production

Important limitation

This portfolio report is a governance and regulatory-screening artifact, not legal advice, certification evidence or a legal compliance determination. Applicability must be validated against actual jurisdiction, legal role, intended purpose, product architecture and national implementing law.

Executive Summary

Duckworks baseline. Duckworks is a fictional European advanced-manufacturing company with approximately 1,200 staff. Project W.I.N.G. covers DuckDesign AI, QuackBot, FeatherForecast, WingInspect Vision, DuckTalent AI, PondGPT and Unregistered GenAI Usage. The project assumes EU/EEA operations but has not fixed an actual Member State, and it deliberately separates internal enterprise risk ratings from statutory classifications.

Overall conclusion. The strongest current legal priorities are AI literacy, prohibited-practice screening, Article 50 transparency for relevant interactive/generative AI, GDPR/privacy governance, employment non-discrimination, existing machinery/product-safety duties, likely NIS2 scoping, and immediate CRA reporting-readiness analysis. DuckTalent should be treated as a future Annex III high-risk design target. Product-integrated safety AI requires separate Article 6(1) analysis.

Now	AI literacy; Article 50 transparency; GDPR; employment equality; product safety; shadow AI containment; NIS2 applicability; CRA scope.
Near-term	CRA Article 14 reporting begins 11 Sep 2026; product liability transition begins Dec 2026; Machinery Regulation transition begins Jan 2027.
Future high-risk AI	DuckTalent: Annex III high-risk rules from 2 Dec 2027. Product-route high-risk AI: 2 Aug 2028 if Art. 6(1) conditions are met.
Governance architecture	Law = mandatory floor; official regulator guidance = interpretation; ISO/NIST/ENISA = voluntary control architecture; Duckworks internal methodology = proportional governance above the legal floor.

1. Research Scope, Evidence Hierarchy and Assumptions

1.1 Evidence hierarchy

- 1. Binding legal text: EUR-Lex / Official Journal consolidated legislation where available.
- 2. Official regulator/competent-authority guidance: European Commission, EDPB and ENISA.
- 3. Formal standards/frameworks: ISO/IEC and NIST, clearly identified as voluntary unless made binding by contract, policy or another legal mechanism.
- 4. Recognized technical references: MITRE ATLAS and OWASP GenAI guidance, used for threat/control design rather than legal claims.
- 5. Duckworks organizational practices and project assumptions: internally binding only if adopted by Duckworks; not external law.

1.2 Project assumptions that materially affect legal conclusions

Assumption	Current project position
Jurisdiction	Duckworks operates primarily in the EU/EEA and sells products into European markets; exact Member State remains unconfirmed.
Human authority	Humans retain formal accountability for employment, product release, quality, procurement and material customer decisions; this must be validated system-by-system.
DuckTalent	Parses, compares, ranks and recommends applicants but does not autonomously issue final hiring/rejection decisions.
DuckDesign / WingInspect	Outputs are advisory / defect flags, with competent humans retaining final design or inspection authority; this remains critical to validate.
Third parties	Duckworks uses a mix of internally developed and third-party AI models/services.

Data	Systems may process confidential IP and selected customer, employee or applicant personal data.
Product scope	Some products may include digital/connected functionality; exact machinery, CRA and AI-product-route applicability is product-specific.
Legal status	Regulatory mappings are screening outputs, not formal legal opinions.

2. Mandatory and Conditional Legal Findings

L-01 EU jurisdiction and market nexus must be validated before a definitive legal conclusion.

Classification	Mandatory legal scoping
Source / provision	AI Act Art. 2; GDPR Art. 3; national implementation of directives S01, S10, S17
Applicability	Duckworks is assumed to operate primarily in the EU/EEA and sell into European markets. This supports EU screening but does not establish the exact Member State law.
Timing / status	Current
Uncertainty / action	Uncertainty: High. Duckworks action: Replace fictional location with an assumed EU Member State for portfolio legal mapping; validate jurisdiction per system.

L-02 Duckworks must determine whether each capability is an AI system and determine its legal role in the AI value chain.

Classification	Mandatory legal requirement
Source / provision	AI Act Arts. 2-3; provider/deployer definitions and scope S01, S09
Applicability	Applies to each material use case before classification. Duckworks may be provider, deployer, or both depending on development, branding, modification and supply arrangements.
Timing / status	Current
Uncertainty / action	Uncertainty: High. Duckworks action: Add AI Act role fields to the inventory and require Legal/Compliance confirmation at intake.

L-03 AI literacy measures are required for staff and other persons dealing with AI on Duckworks behalf.

Classification	Mandatory legal requirement
Source / provision	AI Act Art. 4 S01, S04
Applicability	Applies broadly because Duckworks develops, procures and uses AI, including employee use of public GenAI. Measures should reflect role, experience, context and system risk.
Timing / status	Applicable since 2 Feb 2025; enforcement regime now active
Uncertainty / action	Uncertainty: Medium. Duckworks action: Implement role-based AI literacy; retain training/guidance records. No specific certificate, AI officer or governance board is mandated by Art. 4.

L-04 Every use case should be screened against prohibited AI practices.

Classification	Mandatory legal requirement
Source / provision	AI Act Art. 5 S01, S08, S03
Applicability	No current Duckworks use case is clearly prohibited on the stated facts. Future workplace emotion-recognition or other prohibited functionality would change the conclusion.

Timing / status	Current; prohibitions 1-8 applicable since 2 Feb 2025; additional 2026 prohibition applies from Dec 2026
Uncertainty / action	Uncertainty: High. Duckworks action: Include prohibited-practice screening as a mandatory intake gate and significant-change trigger.

L-05 QuackBot likely requires clear disclosure that the customer is interacting with AI.

Classification	Mandatory legal requirement
Source / provision	AI Act Art. 50(1) S01, S05
Applicability	QuackBot is intended to interact directly with natural persons. Provider/deployer role must be confirmed, but explicit disclosure is the most defensible implementation.
Timing / status	Applicable from 2 Aug 2026
Uncertainty / action	Uncertainty: Medium. Duckworks action: Add persistent, accessible AI-interaction disclosure and test it in release acceptance criteria.

L-06 PondGPT may fall under direct-interaction transparency requirements.

Classification	Conditional mandatory requirement
Source / provision	AI Act Art. 50(1) S01, S05
Applicability	Relevant when employees interact directly with PondGPT and Duckworks is legally the provider. The exception where interaction with AI is obvious may be relevant but should not be assumed without rationale.
Timing / status	Applicable from 2 Aug 2026
Uncertainty / action	Uncertainty: Medium. Duckworks action: Document the Art. 50 analysis; use explicit internal disclosure unless Legal determines the obvious-interaction exception is safely relied upon.

L-07 Providers of qualifying generative AI systems can have machine-readable marking/detection obligations for synthetic content.

Classification	Conditional mandatory requirement
Source / provision	AI Act Art. 50(2) and associated exceptions S01, S05, S06
Applicability	Potentially relevant to PondGPT, QuackBot and DuckDesign if Duckworks is the provider and the system generates covered content. Vendor-provider status changes responsibility.
Timing / status	Applicable from 2 Aug 2026, subject to transition/exception details
Uncertainty / action	Uncertainty: High. Duckworks action: Perform provider-role and output-type analysis; contractually obtain vendor evidence where a third party is provider.

L-08 DuckTalent is very likely an Annex III high-risk AI system because it analyses, filters, ranks and recommends job applicants.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Art. 6(2); Annex III point 4(a) S01, S03, S07
Applicability	The intended purpose closely matches recruitment and candidate-evaluation use cases in Annex III. This is still a preliminary legal classification for the fictional project.
Timing / status	High-risk requirements apply from 2 Dec 2027
Uncertainty / action	Uncertainty: Medium. Duckworks action: Label DuckTalent "Preliminary Annex III High-Risk - legal confirmation required" and design to the future high-risk regime now.

L-09 The Article 6(3) Annex III exception should not presently be relied upon for DuckTalent.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Art. 6(3) S01, S07
Applicability	Ranking and recommendation materially influence employment decisions, making the narrow procedural/preparatory exception difficult to support.
Timing / status	High-risk regime from 2 Dec 2027
Uncertainty / action	Uncertainty: High. Duckworks action: Document an Art. 6(3) assessment but assume high-risk until Legal confirms otherwise.

L-10 A human final hiring decision does not by itself remove DuckTalent from Annex III high-risk classification.

Classification	Legal classification principle
Source / provision	AI Act Art. 6; Annex III point 4(a); Art. 6(3) S01, S07
Applicability	Human review is a critical safeguard, but classification turns primarily on intended purpose and the statutory exception test.
Timing / status	High-risk regime from 2 Dec 2027
Uncertainty / action	Uncertainty: Medium. Duckworks action: Keep meaningful human review as a control, not as the sole basis for avoiding high-risk classification.

L-11 If Duckworks is the provider of DuckTalent, extensive high-risk system requirements will apply.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Arts. 8-25, especially 9-17 and 16 S01
Applicability	Provider-side requirements include risk management, data governance, technical documentation, record-keeping, information to deployers, human oversight, accuracy/robustness/cybersecurity, quality management, conformity and corrective actions.
Timing / status	From 2 Dec 2027 for Annex III route
Uncertainty / action	Uncertainty: High. Duckworks action: Build a provider-readiness workstream only if Duckworks provider status is confirmed; otherwise obtain vendor evidence contractually.

L-12 If Duckworks deploys DuckTalent, high-risk deployer duties will apply.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Art. 26 S01
Applicability	Use per instructions, assign competent/authorised human oversight, monitor operation, manage relevant input data, retain controlled logs and notify workers/representatives where applicable.
Timing / status	From 2 Dec 2027 for Annex III route
Uncertainty / action	Uncertainty: Medium. Duckworks action: Design the Human Oversight Standard, monitoring, log retention and workplace communication process now.

L-13 A statutory AI Act fundamental-rights impact assessment is probably not mandatory for DuckTalent solely because it is recruitment AI.

Classification	Legal applicability conclusion
Source / provision	AI Act Art. 27 S01

Applicability	Art. 27 targets specified deployers, including bodies governed by public law, private entities providing public services, and certain Annex III 5(b)/(c) deployers. Duckworks is a private manufacturer and DuckTalent is Annex III point 4.
Timing / status	When corresponding high-risk duties apply
Uncertainty / action	Uncertainty: Medium. Duckworks action: Keep the Duckworks AIA as an internal/ISO-aligned impact assessment; do not label it an Art. 27 FRIA unless facts change.

L-14 Material rebranding, substantial modification or change of intended purpose can shift provider responsibility to Duckworks.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Art. 25 S01
Applicability	Especially relevant for vendor AI that Duckworks rebrands, materially modifies or changes into a high-risk intended purpose.
Timing / status	As applicable to high-risk systems/value-chain roles
Uncertainty / action	Uncertainty: High. Duckworks action: Add provider-role reassessment triggers to change management and vendor governance.

L-15 Annex III and product-route high-risk AI have different application dates after the 2026 amendment.

Classification	Mandatory legal timing
Source / provision	AI Act Art. 113 as amended by Regulation (EU) 2026/1744 S02, S03
Applicability	DuckTalent follows the Annex III timeline; product-integrated safety AI may follow the Annex I/product route.
Timing / status	Annex III: 2 Dec 2027; product route Art. 6(1): 2 Aug 2028
Uncertainty / action	Uncertainty: Low. Duckworks action: Keep the dates explicitly separated in all portfolio documents and dashboards.

L-16 GDPR applies independently of AI Act risk classification whenever personal data are processed.

Classification	Mandatory legal requirement
Source / provision	GDPR Arts. 3-6, 9, 13-15, 24-25, 28, 32 S10
Applicability	Strong relevance to DuckTalent; likely relevance to QuackBot and PondGPT; possible relevance elsewhere.
Timing / status	Current
Uncertainty / action	Uncertainty: Medium. Duckworks action: Add GDPR screening to every AI intake; do not use AI Act classification as a proxy for privacy risk.

L-17 DuckTalent personal-data processing must satisfy GDPR principles, lawful-basis, transparency, minimisation, accuracy and accountability requirements.

Classification	Mandatory legal requirement
Source / provision	GDPR Arts. 5-6; Art. 9 where special-category data are involved; Arts. 13-14 S10
Applicability	Applicant CV parsing, qualification extraction and candidate evaluation involve personal data.
Timing / status	Current

Uncertainty / action

Uncertainty: High. Duckworks action: Define controller/processor roles, purpose, lawful basis, notice, retention, minimisation and data-quality controls before production.

L-18 GDPR Article 22 is not automatically triggered merely because DuckTalent ranks candidates, but superficial human review may not avoid it.**Classification**

Conditional mandatory requirement

Source / provision

GDPR Art. 22; EDPB automated decision-making guidance | S10, S11

Applicability

Art. 22 concerns solely automated decisions producing legal or similarly significant effects. Duckworks assumes humans make final decisions; meaningful involvement must be evidenced.

Timing / status

Current

Uncertainty / action

Uncertainty: High. Duckworks action: Test recruiter authority, time, information and override behaviour; prohibit rubber-stamping and monitor automation bias/override rates.

L-19 A GDPR DPIA is a strong candidate for DuckTalent and must be formally screened.**Classification**

Conditional mandatory requirement

Source / provision

GDPR Art. 35; EDPB DPIA Guidelines | S10, S12

Applicability

Systematic evaluation/profiling in recruitment may create high risk to individuals. A definitive determination also depends on actual processing and national supervisory-authority lists.

Timing / status

Current

Uncertainty / action

Uncertainty: High. Duckworks action: Complete a formal DPIA screening; if triggered, perform the DPIA separately from the broader Duckworks AIA.

L-20 Third-party GenAI does not remove Duckworks GDPR accountability.**Classification**

Mandatory legal requirement

Source / provision

GDPR Arts. 24, 25, 28, 32 and Chapter V where transfers apply | S10, S13

Applicability

Relevant when DuckTalent, QuackBot, PondGPT or shadow AI transmits personal data to external providers.

Timing / status

Current

Uncertainty / action

Uncertainty: High. Duckworks action: Verify processor/controller status, data-use terms, security, subprocessors, retention and international transfers before use.

L-21 Recruitment practices must not create unlawful racial or ethnic discrimination.**Classification**

Mandatory through national law

Source / provision

Directive 2000/43/EC, especially Arts. 1-3 | S14

Applicability

Directly relevant to DuckTalent selection criteria, proxies, ranking and candidate outcomes.

Timing / status

Current through Member-State implementing law

Uncertainty / action

Uncertainty: High. Duckworks action: Map national law and include disparate-impact/proxy-risk testing in production fairness validation.

L-22 Recruitment must not discriminate on religion or belief, disability, age or sexual orientation; reasonable accommodation obligations are relevant.**Classification**

Mandatory through national law

Source / provision

Directive 2000/78/EC, especially Arts. 1-5 | S15

Applicability	Directly relevant to DuckTalent criteria, accessibility and candidate treatment.
Timing / status	Current through Member-State implementing law
Uncertainty / action	Uncertainty: High. Duckworks action: Map national law; validate accessibility and reasonable-accommodation handling; test neutral criteria for indirect discrimination.

L-23 Direct and indirect sex discrimination in recruitment is prohibited.

Classification	Mandatory through national law
Source / provision	Directive 2006/54/EC, especially Arts. 2 and 14 S16
Applicability	Directly relevant to DuckTalent.
Timing / status	Current through Member-State implementing law
Uncertainty / action	Uncertainty: High. Duckworks action: Include sex-based direct/indirect discrimination testing and national-law review.

L-24 Duckworks is a strong candidate for NIS2 scope if its manufacturing activity maps to Annex II/NACE machinery manufacturing and national law captures it.

Classification	Scope-dependent mandatory requirement
Source / provision	NIS2 Arts. 2-3; Annex II (manufacture of machinery and equipment n.e.c.) S17, S18
Applicability	Duckworks has about 1,200 staff and manufactures mechanical/robotic arms. Size and sector point toward likely scope, but exact NACE classification and Member-State implementation remain decisive.
Timing / status	Current through national implementing law
Uncertainty / action	Uncertainty: High. Duckworks action: Change portfolio status from merely "possible" to "likely subject to NACE and national-law confirmation"; obtain country-specific legal mapping.

L-25 If NIS2 applies, management accountability, cybersecurity risk-management and incident-reporting duties cover the wider environment supporting AI.

Classification	Scope-dependent mandatory requirement
Source / provision	NIS2 Arts. 20, 21 and 23 S17, S18
Applicability	AI platforms, suppliers, cloud services, APIs and product systems would sit within organizational cybersecurity risk management where they support the in-scope entity.
Timing / status	Current through national implementing law
Uncertainty / action	Uncertainty: High. Duckworks action: Map existing ISO 27001 controls to NIS2, including supply chain, incident handling, continuity, vulnerability management, access control and management oversight.

L-26 Until transition, machinery placed on the EU market remains governed principally by Machinery Directive 2006/42/EC where in scope.

Classification	Current product-safety requirement
Source / provision	Machinery Directive Art. 5 and Annex I S21, S23
Applicability	Relevant to Duckworks mechanical/robotic arms and to AI-assisted engineering/inspection insofar as those processes influence product conformity and safety evidence.
Timing / status	Generally until 19 Jan 2027
Uncertainty / action	Uncertainty: High. Duckworks action: Maintain current machinery conformity evidence and trace how AI-assisted design/inspection affects safety decisions.

L-27 Machinery Regulation (EU) 2023/1230 generally becomes the replacement machinery regime from 20 January 2027.

Classification	Future product-safety requirement
Source / provision	Machinery Regulation, especially manufacturer obligations and Annex III essential health/safety requirements S22, S23
Applicability	Likely relevant to Duckworks machinery products.
Timing / status	Generally from 20 Jan 2027
Uncertainty / action	Uncertainty: Medium. Duckworks action: Create a transition workstream and align AI/product change evidence with the new machinery conformity process.

L-28 DuckDesign or WingInspect do not become AI Act high-risk merely because they may affect product safety; the Art. 6(1) product route requires specific conditions.

Classification	Conditional future high-risk AI requirement
Source / provision	AI Act Art. 6(1); Annex I S01, S07
Applicability	The AI must itself be a covered product or safety component and the product must require third-party conformity assessment under Annex I legislation. Exact architecture and safety function are not yet validated.
Timing / status	High-risk product-route duties from 2 Aug 2028
Uncertainty / action	Uncertainty: High. Duckworks action: Confirm whether any AI performs a safety function, directly controls movement, or is embedded as a safety component.

L-29 The Cyber Resilience Act may apply to connected Duckworks products with digital elements.

Classification	Scope-dependent mandatory requirement
Source / provision	CRA scope and Art. 13 manufacturer obligations S19, S20
Applicability	Potentially relevant to connected robotic arms, embedded software or commercial digital components. Internal business applications are not automatically CRA products.
Timing / status	Main obligations from 11 Dec 2027
Uncertainty / action	Uncertainty: High. Duckworks action: Perform product-by-product CRA scoping, including software, connectivity, remote processing and commercial availability.

L-30 CRA vulnerability/incident reporting obligations begin before the main CRA regime.

Classification	Near-term mandatory requirement
Source / provision	CRA Art. 14 S19, S20
Applicability	Applies to in-scope products with digital elements, including relevant products made available before full application according to CRA transition rules.
Timing / status	From 11 Sep 2026
Uncertainty / action	Uncertainty: High. Duckworks action: Complete CRA scope triage immediately; establish reporting ownership, thresholds, contacts and evidence before 11 Sep 2026.

L-31 For in-scope products, the CRA main manufacturer lifecycle cybersecurity obligations apply from 11 December 2027.

Classification	Future mandatory requirement
Source / provision	CRA Art. 13 and Annex I; related conformity/technical documentation provisions S19, S20

Applicability	Product-specific.
Timing / status	From 11 Dec 2027
Uncertainty / action	Uncertainty: Medium. Duckworks action: Build secure-by-design, vulnerability handling, support-period, technical documentation and conformity evidence into product lifecycle governance.

L-32 The General Product Safety Regulation applies where Duckworks offers consumer products within its scope.

Classification	Scope-dependent mandatory requirement
Source / provision	GPSR Arts. 5-6 S24
Applicability	Current facts do not establish whether Duckworks arms are consumer products versus specialist/industrial machinery.
Timing / status	Applicable since 13 Dec 2024
Uncertainty / action	Uncertainty: High. Duckworks action: Keep GPSR as conditional; determine intended consumer/industrial market for each product line.

L-33 The revised Product Liability Directive expressly covers modern software, including AI, and applies to products placed on the market or put into service after 9 December 2026.

Classification	Future/national liability regime
Source / provision	Directive (EU) 2024/2853, scope/application provisions S25
Applicability	Relevant to defective product outcomes involving software/AI and cybersecurity defects, subject to national transposition and specific claim facts.
Timing / status	Products after 9 Dec 2026; national transposition required
Uncertainty / action	Uncertainty: Medium. Duckworks action: Strengthen traceability, validation, change history, incident records and supplier evidence for product-integrated AI.

L-34 High-risk AI used in the workplace creates employee/worker-representative information duties in addition to general employer obligations.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Art. 26 S01
Applicability	Relevant to DuckTalent if high-risk and used by Duckworks as employer.
Timing / status	From 2 Dec 2027 for Annex III DuckTalent
Uncertainty / action	Uncertainty: Medium. Duckworks action: Include workforce/representative notification and consultation checkpoint in DuckTalent deployment planning, subject to national labour law.

L-35 High-risk Annex III systems carry registration/database obligations and supporting documentation expectations.

Classification	Future mandatory high-risk requirement
Source / provision	AI Act Arts. 49 and 71 S01
Applicability	Relevant to DuckTalent if classification is confirmed and depending on Duckworks provider/deployer role.
Timing / status	From high-risk application date
Uncertainty / action	Uncertainty: Medium. Duckworks action: Include registration evidence and EU database readiness in the future compliance plan.

3. Official European and Regulatory Guidance

The items in this section support interpretation and implementation. They do not independently create new statutory duties unless the underlying law does. Draft guidance is explicitly identified as draft.

ID	Status	Conclusion / use	Source basis	Duckworks relevance
G-01	Official non-binding guidance	AI system definition guidelines provide Commission interpretation of what qualifies as an AI system.	Commission AI system definition guidelines S09	Use at intake to prevent over- or under-scoping. The Commission identifies the guidelines as non-binding and evolving. Systems: All systems
G-02	Official non-binding guidance	Prohibited-practices guidelines provide practical examples and legal interpretation for Article 5.	Commission prohibited AI practices guidelines S08	Use in prohibited-practice screening; authoritative interpretation ultimately belongs to courts. Systems: All systems
G-03	Official guidance supporting binding law	Final Article 50 transparency guidelines are the principal current Commission interpretation of transparency duties.	Commission Art. 50 guidelines S05	Apply to QuackBot first, then assess PondGPT and other generative systems by role and output type. Systems: QuackBot; PondGPT; DuckDesign where relevant
G-04	Draft official guidance	Commission high-risk classification guidelines remain draft and should be labelled as such.	Draft high-risk classification guidelines S07	Useful for DuckTalent and the product-safety route, but should not be treated as binding law or final guidance. Systems: DuckTalent; DuckDesign; WingInspect
G-05	Official practical guidance	Commission AI literacy Q&A supports a risk- and role-based literacy programme and confirms no fixed certificate or governance structure is required.	AI Literacy Q&A S04	Use to design role-based training, guidance and recordkeeping. Systems: All systems; shadow AI
G-06	Voluntary compliance tool linked to binding law	The Transparency Code of Practice is voluntary but can be used by signatories to demonstrate compliance with specified Article 50 marking/labelling duties.	Transparency Code of Practice S06	Relevant only where covered provider/deployer transparency duties arise; it does not replace the AI Act or final guidelines. Systems: Generative systems where Article 50(2)/(4)/(5) applies
G-07	Regulatory guidance	EDPB automated decision-making guidance remains important for interpreting meaningful human involvement and profiling under GDPR.	EDPB/WP29 automated decision-making guidance S11	Key for DuckTalent Article 22 analysis and human-review design. Systems: DuckTalent
G-08	Regulatory opinion	EDPB Opinion 28/2024 addresses anonymity, legitimate interest and consequences of unlawful personal-data processing in AI model development/deployment.	EDPB Opinion 28/2024 S13	Useful for third-party model diligence and any Duckworks model-development/deployment involving personal data. Systems: DuckTalent; PondGPT; QuackBot; shadow AI as applicable
G-09	Regulatory guidance	EDPB DPIA guidance supports determining	EDPB-endorsed DPIA Guidelines WP248 rev.01	Use for DuckTalent DPIA screening and other high-

		when processing is likely to result in high risk and therefore requires a DPIA.	S12	impact personal-data AI. Systems: DuckTalent; other personal-data AI
G-10	Official non-binding guidance	The Commission 2026 CRA guidance clarifies scope, substantial modification, support periods, reporting and risk assessment.	CRA implementation guidance S20	Use for Duckworks product scoping and readiness, while treating the CRA text as the binding source. Systems: Connected/product-integrated AI and software
G-11	Official EU cybersecurity guidance	ENISA Multilayer Framework uses three layers: cybersecurity foundations, AI-specific cybersecurity, and sector-specific cybersecurity for AI.	ENISA Multilayer Framework S36	Strong basis for AI threat modelling, lifecycle security and control design. Systems: All systems; especially QuackBot, PondGPT, DuckDesign, WingInspect
G-12	Official EU cybersecurity/standards guidance	ENISA Cybersecurity of AI and Standardisation helps relate AI-specific cybersecurity needs to standards and EU policy.	ENISA Cybersecurity of AI and Standardisation S37	Use as supporting technical rationale, not as a standalone legal obligation. Systems: Portfolio-wide

4. Voluntary Standards and Recognized Framework Guidance

These sources are not legislation. They become binding only where incorporated through contract, internal policy, certification commitments, procurement requirements or another binding mechanism. Alignment does not establish legal compliance.

F-01 NIST AI RMF 1.0 provides the Govern, Map, Measure and Manage functions for socio-technical AI risk management.

Type: Voluntary framework

Relevant public basis: AI RMF Core | S26

Duckworks use: Use as the primary cross-system operating structure. NIST states AI RMF 1.0 is voluntary and is being revised.

Systems: All systems

F-02 NIST AI RMF Playbook provides suggested actions mapped to AI RMF subcategories.

Type: Voluntary implementation guidance

Relevant public basis: Govern / Map / Measure / Manage Playbook | S27

Duckworks use: Use selectively for controls and evidence; NIST says it is not a checklist or ordered implementation sequence.

Systems: All systems

F-03 NIST AI 600-1 identifies GenAI-specific risks and actions as a companion to AI RMF 1.0.

Type: Voluntary GenAI profile

Relevant public basis: NIST AI 600-1 | S28

Duckworks use: Strong for hallucination, information integrity, human-AI configuration, misuse, privacy/security and value-chain risks.

Systems: DuckDesign; QuackBot; PondGPT; shadow GenAI

F-04 NIST SP 800-218A augments the SSDF with AI-model-development practices and is useful to model producers, system producers and acquirers.

Type: Voluntary secure-development guidance

Relevant public basis: SP 800-218A | S29

Duckworks use: Integrate into AI SDLC and acquisition for internally developed or materially integrated AI.

Systems: DuckDesign; QuackBot; PondGPT; WingInspect; DuckTalent depending build model

F-05 ISO/IEC 42001:2023 specifies requirements and guidance for establishing, implementing, maintaining and continually improving an AI management system.

Type: Voluntary/certifiable management system standard

Relevant public basis: Public ISO description; full standard requires authorized access | S30

Duckworks use: Best ISO basis for Duckworks enterprise AI governance operating model, policies, roles, lifecycle governance and continual improvement.

Systems: Portfolio-wide

F-06 ISO/IEC 23894:2023 provides guidance for AI-specific risk management and integration into organizational activities.

Type: Voluntary guidance standard

Relevant public basis: Public ISO description | S31

Duckworks use: Supports Duckworks risk identification, analysis, evaluation, treatment and monitoring methodology.

Systems: Portfolio-wide

F-07 ISO/IEC 42005:2025 provides guidance for AI system impact assessments across the lifecycle, focused on impacts to individuals, groups and society.

Type: Voluntary guidance standard

Relevant public basis: Public ISO description | S32

Duckworks use: Use for Duckworks AIA methodology, especially DuckTalent. Do not equate it to a statutory AI Act FRIA.

Systems: All material systems; DuckTalent core

F-08 ISO/IEC 27001:2022 provides ISMS requirements and can anchor security governance around AI.

Type: Voluntary/certifiable management system standard

Relevant public basis: Public ISO description; Amendment 1:2024 noted | S33

Duckworks use: Reuse ISMS processes for access control, supplier security, incident management, logging, risk treatment and evidence.

Systems: Portfolio-wide

F-09 ISO/IEC 27005:2022 supports information-security risk assessment and treatment.

Type: Voluntary guidance standard

Relevant public basis: Public ISO description | S34

Duckworks use: Use for security-specific risk scenarios within the broader AI risk method.

Systems: Portfolio-wide

F-10 ISO 31000:2018 provides enterprise risk-management principles and guidance.

Type: Voluntary guidance standard

Relevant public basis: Public ISO description | S35

Duckworks use: Use to align AI risk treatment and escalation with enterprise risk management.

Systems: Portfolio-wide

F-11 OECD AI Principles provide a high-level responsible-AI principles layer covering human-centred values, transparency, robustness and accountability.

Type: Intergovernmental voluntary principles

Relevant public basis: OECD AI Principles | S38

Duckworks use: Useful as principles context, not as an auditable substitute for law or control requirements.

Systems: Portfolio-wide

F-12 MITRE ATLAS provides adversarial tactics and techniques for AI-enabled systems.

Type: Recognized technical reference

Relevant public basis: MITRE ATLAS knowledge base | S39

Duckworks use: Use for threat modelling, red-team planning and security scenario development.

Systems: AI security relevant systems

F-13 OWASP GenAI Security Project provides practical security guidance for LLM/GenAI applications.

Type: Community security guidance

Relevant public basis: OWASP GenAI Security Project | S40

Duckworks use: Use for prompt injection, data leakage, excessive agency, insecure integration and related GenAI controls.

Systems: QuackBot; PondGPT; DuckDesign; shadow GenAI

5. System-by-System Applicability

AI-001 - DuckDesign AI

Purpose: Engineering design assistance

Current governance gate: Restricted pilot only

AI Act position: No clear Annex III classification. Art. 4 applies. Product-route high-risk status is conditional on integration/safety-component facts.

Other legal layers: Machinery safety; potential AI Act Art. 6(1); CRA if product-integrated; GDPR if personal data appear; IP/confidentiality.

Voluntary guidance: NIST AI RMF + GenAI Profile; ISO 42001/23894/27001; ENISA; SP 800-218A.

Required Duckworks response: Confirm engineer authority; validate product/safety role; design validation; IP/data controls; no autonomous production release.

AI-002 - QuackBot

Purpose: Customer support

Current governance gate: Production blocked pending gates

AI Act position: Article 50(1) transparency is an immediate priority. Art. 4 applies. No clear Annex III high-risk route on current facts.

Other legal layers: GDPR where customer data processed; Article 50; possible provider-side synthetic-content marking; NIS2 organizational security.

Voluntary guidance: NIST GenAI Profile; ISO 42001/23894/27001; ENISA; OWASP GenAI.

Required Duckworks response: Implement AI disclosure, prompt/RAG security testing, safe escalation, content boundaries, privacy controls, monitoring and complaint handling.

AI-003 - FeatherForecast

Purpose: Supply-chain forecasting

Current governance gate: Continue with monitoring

AI Act position: No current fact places it in Annex III or the product high-risk route. Art. 4 applies.

Other legal layers: NIS2 organizational cybersecurity if Duckworks in scope; GDPR only if personal data are introduced.

Voluntary guidance: NIST AI RMF; ISO 42001/23894/27001; ISO 31000.

Required Duckworks response: Maintain manager approval for material commitments, drift/performance monitoring and data-quality controls.

AI-004 - WingInspect Vision

Purpose: Manufacturing defect detection

Current governance gate: Restricted pilot only

AI Act position: Not automatically AI Act high-risk. Product-route classification depends on whether it is a covered product/safety component requiring third-party conformity assessment. Art. 4 applies.

Other legal layers: Machinery/product safety; CRA if product-integrated; AI Act Art. 6(1) conditional.

Voluntary guidance: NIST AI RMF; ISO 42001/23894/27001; ENISA; SP 800-218A.

Required Duckworks response: Human inspector remains final authority; false-negative testing; validate safety dependence; trace quality decisions.

AI-005 - DuckTalent AI

Purpose: Recruitment screening and ranking

Current governance gate: Do not deploy in current state

AI Act position: Very likely Annex III point 4(a) high-risk; future Arts. 8-26 duties. Art. 4 applies now. Art. 27 FRIA probably not mandatory on current facts.

Other legal layers: GDPR; DPIA screening/likely DPIA; employment/equality law; future AI Act high-risk duties; worker information.

Voluntary guidance: NIST AI RMF; ISO 42001/23894/42005/27001; EDPB guidance.

Required Duckworks response: Legal classification; DPIA; fairness/bias testing; meaningful human review; transparency/contestability; logs; documentation; future conformity readiness.

AI-006 - PondGPT

Purpose: Internal employee AI assistant

Current governance gate: Restricted pilot only

AI Act position: Art. 4 applies. Art. 50(1) may apply depending provider status and obvious-interaction exception. No clear Annex III route on current facts.

Other legal layers: GDPR; confidentiality/IP; third-party/vendor; NIS2 organizational cybersecurity.

Voluntary guidance: NIST GenAI Profile; ISO 42001/23894/27001; ENISA; OWASP GenAI.

Required Duckworks response: Enterprise authorization boundaries; sensitive repository exclusions; prompt/RAG security; logging; acceptable-use controls; vendor terms.

AI-007 - Unregistered GenAI Usage

Purpose: Shadow/uncontrolled employee AI use

Current governance gate: Immediate containment

AI Act position: Not one homogeneous AI system; a discovery condition containing multiple unknown use cases. Art. 4 still matters.

Other legal layers: GDPR, confidentiality, IP, security, procurement and contractual duties depend on each discovered use case.

Voluntary guidance: NIST GenAI Profile; ISO 42001/27001; ENISA; OWASP GenAI.

Required Duckworks response: Discover and decompose uses, prevent restricted-data uploads, approve tools, register material use cases, investigate suspected exposures and train users.

6. Governance Practices: Correct Legal Characterization

ID	Practice	Correct characterization	Portfolio treatment	Reason
IP-01	Central AI inventory	Recommended organizational practice; specific legal documentation/registration duties exist for defined categories, but there is no single blanket AI Act duty to inventory every low-risk internal AI system.	Retain as core Duckworks control.	NIST/ISO aligned; supports legal scoping and evidence.
IP-02	AI Governance Committee	Recommended organizational practice; Article 4 does not mandate a specific AI officer or governance board.	Retain because Duckworks needs cross-functional decision rights.	Commission AI literacy Q&A confirms no specific governance structure is mandated for Art. 4.
IP-03	AI impact assessment for all seven entries	Internal governance practice informed by ISO/IEC 42005; not automatically an EU AI Act FRIA.	Keep "Duckworks AIA" terminology and separately identify statutory DPIA/FRIA where triggered.	Avoid false legal equivalence.
IP-04	Low/Moderate/High/	Duckworks enterprise	Keep terminology strictly	Already a strong project

	Critical internal risk ratings	methodology, not EU AI Act legal classification.	separated in all artifacts.	design choice.
IP-05	Human review	Can be a legal requirement for high-risk systems and a recommended control elsewhere.	Specify competence, authority, information, override, escalation and evidence - not merely "human in the loop".	Critical for DuckTalent, DuckDesign and WingInspect.
IP-06	AI vendor due diligence	Recommended broadly and mandatory in particular legal contexts such as GDPR processors, NIS2 supply-chain risk and product/cyber rules.	Integrate security, privacy, data-use, IP, change, incident, resilience and exit clauses.	Do not treat contract transfer as transfer of accountability.
IP-07	AI evidence repository	Recommended enterprise-wide; specific legal contexts create documentation/logging/ac countability duties, but no universal statute requires one repository.	Retain as assurance-readiness architecture.	Supports Internal Audit and legal defensibility.
IP-08	ISO/IEC 42001 certification	Optional. The standard can be implemented/mapped without certification.	Do not claim certification or legal compliance from mapping alone.	Full clause-level conformity claims require authorized access to the standard text.

7. Prioritized Action Register

ID	Priority	Action	Owner	Why	Trace	Status
P0-01	Immediate	Implement QuackBot AI disclosure	Customer Operations / Legal / AI Governance	Art. 50 applies now; QuackBot is directly interactive.	L-05	Open
P0-02	Immediate	Operationalize role-based AI literacy and evidence records	AI Governance / HR / System Owners	Art. 4 already applies across Duckworks AI use.	L-03	Open
P0-03	Immediate	Add prohibited-practice screening to AI intake/change process	Legal / AI Governance	Current legal gate; future functionality can change classification.	L-04	Open
P0-04	Immediate	Contain and decompose shadow GenAI use	CISO / AI Governance / IT	Unknown tools may process confidential or personal data without review.	L-16, L-20	Open
P0-05	Immediate	Keep DuckTalent blocked from unrestricted production	CPO / Legal / CRCO	Likely Annex III high-risk and unresolved privacy/fairness/human oversight issues.	L-08, L-18, L-19	Open
P0-06	Immediate	Perform CRA product scoping and reporting-readiness assessment	Product Security / Legal / CISO	Art. 14 reporting starts 11 Sep 2026 for in-scope products.	L-29, L-30	Open
P0-07	Immediate	Assign AI Act provider/deployer roles per system	Legal / Procurement / AI Governance	Obligations materially differ by economic-operator role.	L-02, L-14	Open
P1-01	0-90 days	Perform formal DuckTalent GDPR DPIA screening / DPIA as required	DPO / HR / Legal	Recruitment profiling may be high-risk processing.	L-19	Open
P1-02	0-90 days	Define and test	Business Owners /	Human authority	L-10, L-18, L-28	Open

		meaningful human oversight for DuckTalent, DuckDesign and WingInspect	Risk / Data & AI	and automation-bias controls are critical to legal and residual-risk conclusions.		
P1-03	0-90 days	Validate NIS2 NACE scope and Member-State implementing law	CISO / Legal	Duckworks appears likely within machinery manufacturing scope but national mapping is required.	L-24, L-25	Open
P1-04	0-90 days	Validate product architecture and safety role of DuckDesign/WingInspect/product AI	CTO / Product Safety / Legal	Determines machinery, AI Act product-route and CRA exposure.	L-26, L-28, L-29	Open
P1-05	0-90 days	Strengthen third-party AI due diligence and contractual evidence requirements	Procurement / Security / Privacy / Legal	Vendor AI does not transfer accountability automatically.	L-14, L-20	Open
P1-06	0-90 days	Update QuackTrack inventory fields for legal role, legal class, data, vendor and reassessment triggers	AI Governance Lead	Supports traceability and avoids conflating enterprise risk with legal classification.	L-02, L-08	Open
P1-07	0-90 days	Establish a governed AI evidence repository / evidence index	AI Governance / Control Owners	Needed to prove operation of legal, risk and internal controls.	Internal governance conclusion	Open
P2-01	2027 readiness	Build DuckTalent high-risk provider/deployer readiness pack	HR / Data & AI / Legal / Risk	Future Arts. 8-26 obligations may require QMS, risk management, data governance, technical documentation, logs, oversight and monitoring.	L-11, L-12, L-35	Planned
P2-02	2027 readiness	Prepare Machinery Regulation transition evidence	Product Engineering / Product Safety	Machinery Regulation generally applies from 20 Jan 2027.	L-27	Planned
P2-03	2027 readiness	Prepare full CRA lifecycle compliance for in-scope products	Product Security / Engineering	Main CRA obligations apply 11 Dec 2027.	L-31	Planned
P2-04	2027-2028 readiness	Assess Art. 6(1) product-route high-risk AI and conformity integration	Legal / Product Safety / AI Governance	Product-integrated high-risk AI duties apply from 2 Aug 2028 if statutory criteria are met.	L-28, L-15	Planned

8. Regulatory and Readiness Timeline

Date	Regime	Milestone	Duckworks implication
2025-02-02	AI Act	AI literacy (Art. 4) and first set of prohibited practices become applicable	Current Duckworks obligations / screening
2026-08-02	AI Act	General application milestone; Article 50 transparency obligations	QuackBot disclosure and other transparency analysis now operational

		apply	
2026-09-11	CRA	Article 14 reporting obligations apply	Immediate product scoping/reporting readiness if Duckworks has in-scope products with digital elements
2026-12-02	AI Act	Additional prohibition introduced by 2026 amendment applies	Maintain prohibited-practice screening for new functionality
2026-12-09	Product Liability Directive	Revised regime applies to products placed on market or put into service after this date, subject to national transposition	Increase product/software/AI traceability and evidence
2027-01-20	Machinery Regulation	Regulation (EU) 2023/1230 generally applies	Transition Duckworks machinery conformity processes
2027-12-02	AI Act	High-risk rules for Annex III systems apply	DuckTalent target compliance date
2027-12-11	CRA	Main CRA obligations apply	In-scope connected products must meet lifecycle cybersecurity and conformity requirements
2028-08-02	AI Act	High-risk rules for Article 6(1) product-route systems apply	Potential product-integrated safety AI target date

9. Portfolio Conclusions and Interview-Defensible Position

- DuckTalent is the clearest legal-design priority. It should be treated as preliminary Annex III high-risk, while keeping Duckworks internal Critical risk separate from the statutory classification.
- QuackBot has an immediate transparency obligation analysis under Article 50. An explicit customer-facing AI disclosure is the safest current implementation.
- AI literacy is an operating obligation now, not a future roadmap item. The programme can be risk- and role-based and does not require a specific certificate or governance board.
- WingInspect and DuckDesign require product/safety architecture validation. Safety impact alone does not automatically make them high-risk under the AI Act; Article 6(1) has a specific product/safety-component and conformity-assessment test.
- NIS2 is more than a remote possibility for a 1,200-person machinery manufacturer. The exact result depends on NACE classification and Member-State implementing law.
- The CRA is a near-term priority because reporting obligations start 11 September 2026 for in-scope products with digital elements, before the main 2027 regime.
- GDPR and equality law apply independently of the AI Act. A human decision at the end of DuckTalent does not eliminate privacy, discrimination or meaningful-human-review concerns.
- ISO/IEC 42001, ISO/IEC 23894, ISO/IEC 42005, ISO/IEC 27001 and NIST AI RMF provide a strong voluntary governance/control architecture, but they should never be presented as proof of EU legal compliance or certification.
- The project design principle remains sound: legal requirements establish the minimum floor, official guidance supports interpretation, voluntary standards/frameworks structure governance, and Duckworks risk methodology determines proportionate internal controls above that floor.

Appendix A - Source Register

All web sources below were verified against official or recognized publisher pages during the research cycle ending 10 August 2026. ISO entries use public descriptions only; detailed clause-level claims require authorized access to the standards.

S01 - EU Artificial Intelligence Act - Regulation (EU) 2024/1689, consolidated 27 July 2026

Type: Binding EU regulation

URL: <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng>

S02 - Regulation (EU) 2026/1744 - Digital Omnibus on AI

Type: Binding amending EU regulation

URL: <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng>

S03 - European Commission - AI Act regulatory framework / implementation timeline

Type: Official Commission information

URL: <https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai>

S04 - European Commission - AI Literacy: Questions & Answers

Type: Official Commission interpretive guidance

URL: <https://digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers>

S05 - European Commission - Guidelines on transparency obligations under Article 50

Type: Official Commission guidance

URL: <https://digital-strategy.ec.europa.eu/en/library/guidelines-transparency-obligations-providers-and-deployers-ai-systems>

S06 - European Commission - Code of Practice on Transparency of AI-generated Content

Type: Voluntary compliance tool endorsed by Commission/AI Board

URL: <https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content>

S07 - European Commission - Draft guidelines on classification of high-risk AI systems

Type: Draft, non-binding Commission guidance

URL: <https://digital-strategy.ec.europa.eu/en/library/draft-commission-guidelines-classification-high-risk-ai-systems>

S08 - European Commission - Guidelines on prohibited AI practices

Type: Non-binding Commission guidance

URL: <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-prohibited-artificial-intelligence-ai-practices-defined-ai-act>

S09 - European Commission - Guidelines on AI system definition

Type: Non-binding Commission guidance

URL: <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-ai-system-definition-facilitate-first-ai-acts-rules-application>

S10 - General Data Protection Regulation - Regulation (EU) 2016/679

Type: Binding EU regulation

URL: <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>

S11 - EDPB - Guidelines on Automated Individual Decision-Making and Profiling

Type: Regulatory guidance endorsed by EDPB

URL: https://www.edpb.europa.eu/documents/guideline/automated-decision-making-and-profiling_en

S12 - EDPB - Endorsed WP29 Guidelines, including DPIA Guidelines WP248 rev.01

Type: Regulatory guidance

URL: https://www.edpb.europa.eu/endorsed-wp29-guidelines_en

S13 - EDPB Opinion 28/2024 on data protection aspects related to AI models

Type: Regulatory opinion

URL: https://www.edpb.europa.eu/documents/opinion-of-the-board-art-64/opinion-282024-on-certain-data-protection-aspects-related-to_en

S14 - Council Directive 2000/43/EC - racial or ethnic equality

Type: EU directive; national implementation required

URL: <https://eur-lex.europa.eu/eli/dir/2000/43/oj/eng>

S15 - Council Directive 2000/78/EC - equal treatment in employment and occupation

Type: EU directive; national implementation required

URL: <https://eur-lex.europa.eu/eli/dir/2000/78/oj/eng>

S16 - Directive 2006/54/EC - equal opportunities and equal treatment of men and women in employment

Type: EU directive; national implementation required

URL: <https://eur-lex.europa.eu/eli/dir/2006/54/oj/eng>

S17 - NIS2 Directive - Directive (EU) 2022/2555

Type: EU directive; national implementation required

URL: <https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:02022L2555-20221227>

S18 - European Commission - NIS2 Directive policy page

Type: Official Commission information

URL: <https://digital-strategy.ec.europa.eu/en/policies/nis2-directive>

S19 - Cyber Resilience Act - Regulation (EU) 2024/2847

Type: Binding EU regulation

URL: <https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng>

S20 - European Commission - 27 July 2026 CRA implementation guidance

Type: Official, non-binding Commission guidance

URL: <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-new-guidance-support-timely-cyber-resilience-act-implementation>

S21 - Machinery Directive 2006/42/EC

Type: EU directive applicable until Machinery Regulation transition

URL: <https://eur-lex.europa.eu/eli/dir/2006/42/oj/eng>

S22 - Machinery Regulation - Regulation (EU) 2023/1230

Type: Binding EU regulation; generally applies from 20 January 2027

URL: <https://eur-lex.europa.eu/eli/reg/2023/1230/oj/eng>

S23 - EUR-Lex - Machinery safety requirements summary

Type: Official EU summary

URL: <https://eur-lex.europa.eu/EN/legal-content/summary/machinery-safety-requirements.html>

S24 - General Product Safety Regulation - Regulation (EU) 2023/988

Type: Binding EU regulation

URL: <https://eur-lex.europa.eu/eli/reg/2023/988/oj/eng>

S25 - Product Liability Directive - Directive (EU) 2024/2853

Type: EU directive; national implementation required

URL: <https://eur-lex.europa.eu/eli/dir/2024/2853/oj/eng>

S26 - NIST AI Risk Management Framework (AI RMF 1.0)

Type: Voluntary framework

URL: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

S27 - NIST AI RMF Playbook

Type: Voluntary implementation guidance

URL: <https://airc.nist.gov/airmf-resources/playbook/>

S28 - NIST AI 600-1 - Generative AI Profile

Type: Voluntary NIST profile

URL: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>

S29 - NIST SP 800-218A - Secure Software Development Practices for Generative AI and Dual-Use Foundation Models

Type: Voluntary NIST secure development guidance

URL: <https://csrc.nist.gov/pubs/sp/800/218/a/final>

S30 - ISO/IEC 42001:2023 - Artificial intelligence management system

Type: International management system standard

URL: <https://www.iso.org/standard/42001>

S31 - ISO/IEC 23894:2023 - Guidance on AI risk management

Type: International guidance standard

URL: <https://www.iso.org/standard/77304.html>

S32 - ISO/IEC 42005:2025 - AI system impact assessment

Type: International guidance standard

URL: <https://www.iso.org/standard/42005>

S33 - ISO/IEC 27001:2022 - Information security management systems

Type: International management system standard

URL: <https://www.iso.org/standard/27001>

S34 - ISO/IEC 27005:2022 - Information security risk management

Type: International guidance standard

URL: <https://www.iso.org/standard/80585.html>

S35 - ISO 31000:2018 - Risk management guidelines

Type: International guidance standard

URL: <https://www.iso.org/standard/65694.html>

S36 - ENISA - Multilayer Framework for Good Cybersecurity Practices for AI

Type: Official EU cybersecurity good-practice guidance

URL: <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>

S37 - ENISA - Cybersecurity of AI and Standardisation

Type: Official EU cybersecurity/standardisation guidance

URL: <https://www.enisa.europa.eu/publications/cybersecurity-of-ai-and-standardisation>

S38 - OECD AI Principles

Type: Intergovernmental responsible-AI principles

URL: <https://oecd.ai/en/ai-principles>

S39 - MITRE ATLAS

Type: Recognized AI adversarial threat knowledge base

URL: <https://atlas.mitre.org/>

S40 - OWASP GenAI Security Project / LLM Top 10

Type: Community security guidance

URL: <https://genai.owasp.org/>

Appendix B - Research Maintenance Rules

- Re-check the consolidated EU AI Act before making any statement about application dates, classifications or obligations.
- Re-check the CRA implementation page before September 2026 reporting-readiness decisions and before the 2027 full-application date.
- For EU directives (NIS2, equality directives, Product Liability Directive), map the actual Member-State implementing law before making a real-world compliance determination.
- Record the research date and source version in each system impact/risk assessment.
- Use current consolidated legislation for working analysis while retaining original and amending acts in the legal evidence trail.
- Distinguish mandatory legal requirements, official non-binding guidance, voluntary standards/frameworks, internal Duckworks requirements and project assumptions in every control mapping.
- Do not claim ISO/NIST/ENISA/OWASP/MITRE alignment proves legal compliance.
- Do not treat Duckworks High/Critical risk ratings as equivalent to EU AI Act high-risk classification.
- Validate material assumptions whenever intended purpose, affected persons, decision authority, model/vendor, data, safety function, geography or legal role changes.

Appendix C - Portfolio Disclaimer

Duckworks, Project W.I.N.G., all personnel, AI systems, datasets, decisions, risks and evidence described in this report are fictional and created solely for educational and professional portfolio purposes. This document uses synthetic/project facts and public sources. It is not legal advice, a legal opinion, certification evidence, an independent audit report or a statement of regulatory conformity.